COMPTIA SECURITY+ SY0-701 DOMAIN 4 · SECURITY OPERATIONS (28%)

Security+ 4.1 · Secure Baselines

Mestre CyberSec · **Lesson 4.1 — Secure Baselines** (4:11) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Executive Lesson Summary:** Baseline = config PADRÃO que toda máquina tem: imagem gold (CIS hardened), patch automático, MFA, EDR. Deploy automatizado: GPO, Intune, Ansible, SCCM — NUNCA manual.

💡 Key Exam Highlights & Critical Concepts

- Baseline: o mínimo de config que toda máquina segue
- Deploy automatizado (GPO/Intune): nunca manual

🎯 Exam Tips & Typical CompTIA Scenarios

- 'baseline configuration applied to all workstations'=secure baseline

🧯 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 4.1 — Secure Baselines)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Secure Baseline (N/A)

A documented, standardized minimum security configuration applied to all systems in a group, often including hardened settings, patching, MFA, and EDR. It ensures consistency and reduces attack surface.

⚠️ ***Exam Trap:*** *Se a questão falar em 'baseline configuration applied to all workstations' ou 'standard security configuration', a resposta é secure baseline.*

• Gold Image (N/A)

A master OS/software image preconfigured to the secure baseline and used to deploy new systems consistently. It is often hardened with CIS benchmarks before cloning.

⚠️ ***Exam Trap:*** *Gold image = modelo padronizado; não confunda com backup. É a fonte para implantação automatizada.*

• System Hardening (N/A)

The process of securing a system by reducing its attack surface, such as disabling unused services, ports, accounts, and applying secure configurations. It is a key part of creating a secure baseline.

⚠️ ***Exam Trap:*** *Hardening não é só patch; envolve remover/desabilitar o que não é necessário. CIS benchmarks fornecem guias de hardening.*

• CIS Benchmarks

Prescriptive, consensus-based security configuration guidelines from the Center for Internet Security, used to harden OSes, applications, and cloud environments. They help define secure baseline settings.

⚠️ ***Exam Trap:*** *CIS = benchmark de hardening reconhecido. Se a questão citar 'hardened image' ou 'industry-standard secure configuration', pense em CIS.*

• Group Policy Object (GPO)

A Microsoft Active Directory feature used to centrally deploy and enforce security settings, including secure baselines, to domain-joined Windows systems. It automates configuration at scale.

⚠️ ***Exam Trap:*** *GPO é para ambiente Windows/Active Directory. Se a questão pede implantação automatizada de baseline em domínio, escolha GPO.*

• Microsoft Intune

A cloud-based endpoint management and mobile device management (MDM) service used to deploy security baselines, policies, and applications to Windows, macOS, iOS, and Android devices. It supports automated, remote baseline enforcement.

⚠️ ***Exam Trap:*** *Intune = gerenciamento moderno em nuvem; GPO = tradicional on-premises AD. Escolha Intune para dispositivos não domínio/nuvem.*

• System Center Configuration Manager (SCCM)

A Microsoft on-premises management tool, now Microsoft Endpoint Configuration Manager, for deploying software, patches, and compliance settings to large Windows environments. It can distribute secure baselines and enforce configuration.

⚠️ ***Exam Trap:*** *SCCM/MECM = gerenciamento on-premises de grandes frotas Windows. Distinga de Intune (nuvem) e GPO (políticas de domínio).*

• Ansible (N/A)

An open-source automation tool used for configuration management, application deployment, and orchestration. It can enforce secure baselines across servers and network devices using playbooks, often agentless over SSH.

⚠️ ***Exam Trap:*** *Ansible = automação agentless e playbooks; não é ferramenta Microsoft. Se a questão citar automação multi-plataforma/Linux, pense em Ansible.*

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A company is rolling out 500 new workstations and the security team must guarantee identical, hardened configurations—including CIS-aligned settings, automatic patching, EDR agents, and MFA enforcement—on every device. Which deployment approach BEST ensures a consistent secure baseline across the fleet?

A) Have each technician manually configure every workstation using a printed hardening checklist

B) Build a CIS-hardened gold image and deploy it enterprise-wide through System Center Configuration Manager (SCCM)

C) Ship bare-metal workstations and let end users install whichever security tools they prefer

D) Configure security settings individually only after each user logs in for the first time

QUESTION 2 · EXAM SCENARIO

After a PCI-DSS audit, an organization must apply CIS Benchmark hardening to 200 Linux servers. The security team requires an automated, repeatable, version-controlled, and auditable solution. Which approach BEST meets this requirement?

A) Hire an external consultant to manually SSH into each server and apply the CIS settings by hand

B) Use Ansible playbooks that reference the CIS Benchmarks to automate hardening at scale across all servers

C) Publish the CIS settings in a wiki page and trust each Linux administrator to apply them when convenient

D) Disable every non-essential service through ad-hoc shell scripts saved only on individual laptops

QUESTION 3 · EXAM SCENARIO

A financial firm must enforce password complexity, account lockout policies, and USB storage restrictions across 2,000 domain-joined Windows machines. The security architect needs a centralized and scalable solution. Which mechanism BEST applies these baseline settings?

A) Configure the Local Security Policy manually on each individual computer

B) Create and link Group Policy Objects (GPOs) in Active Directory to push baseline settings to all domain-joined computers

C) Email a registry script to each user and ask them to run it as administrator on their own machine

D) Disable policy enforcement to avoid generating user help-desk tickets

QUESTION 4 · EXAM SCENARIO

After a shift to remote work, many of a company's employees use laptops from home networks, hotels, and coffee shops. The CISO requires that every laptop receive the same security baseline regardless of whether it ever connects to the corporate LAN. Which solution BEST meets this requirement?

A) Require every remote employee to bring their laptop to headquarters annually for inspection and reconfiguration

B) Use Microsoft Intune to push and continuously enforce baseline policies from the cloud on every enrolled device

C) Deploy only on-premises Group Policy that requires a permanent VPN connection to apply

D) Distribute a PDF document containing security instructions to each remote employee

QUESTION 5 · EXAM SCENARIO

A DevOps engineer must ensure that 150 production servers maintain a consistent security configuration and that any configuration drift is automatically corrected without manual intervention. Which tool and methodology BEST fit this requirement?

A) Manually SSH into each server weekly to run hardening commands and hope nothing changes in between

B) Use Ansible with idempotent playbooks referencing the CIS-hardened secure baseline, run on a continuous schedule

C) Ask each system administrator to memorize and personally apply best practices on the servers they own

D) Rely on end users to file help-desk tickets when they suspect a misconfigured server

QUESTION 6 · EXAM SCENARIO

The compliance team must verify that all 3,000 endpoints in the organization continue to adhere to the approved secure baseline over time. Which approach BEST validates baseline adherence at scale?

A) Trust system administrators to honestly self-report their compliance status each quarter

B) Conduct random visual inspections of desktops during occasional site visits

C) Use automated compliance-scanning tools that compare the live endpoint state against the gold image baseline

D) Skip verification because the original gold image was already validated before deployment

QUESTION 7 · EXAM SCENARIO

A manufacturing firm suffered a ransomware incident that exploited endpoints lacking EDR and running outdated patches. The CIO wants to ensure that, going forward, every endpoint is shipped with EDR, automatic patching, MFA, and CIS hardening applied consistently. Which control BEST prevents recurrence?

A) Send quarterly email reminders to end users telling them to install updates when convenient

B) Build a secure baseline that bundles mandatory EDR, automatic patching, MFA, and CIS hardening, and deploy it through Intune and SCCM

C) Disable security tools during scheduled maintenance windows to reduce system overhead

D) Allow each department to independently select its own security stack based on local preference

QUESTION 8 · EXAM SCENARIO

A hospital must comply with HIPAA and needs every workstation that handles PHI to follow a consistent, hardened configuration. Which approach BEST establishes a secure baseline for these endpoints?

A) Implement a CIS-hardened gold image with EDR, MFA, and automated patching, and deploy it via enterprise management tooling such as SCCM or Intune

B) Rely solely on a consumer-grade antivirus product to protect all PHI workstations

C) Allow clinical staff to use their personal smartphones and laptops without any configuration standards

D) Skip hardening to simplify IT operations and reduce help-desk tickets

QUESTION 9 · EXAM SCENARIO

A Windows-centric organization wants to leverage Microsoft's own recommended security baseline settings across its server fleet. Which approach BEST uses Microsoft tooling to deploy these baselines at scale?

A) Manually configure each server by copying settings from screenshots posted on Microsoft's website

B) Import the Microsoft Security Baselines as ADMX templates, deploy them through Group Policy, and enforce via SCCM

C) Skip Microsoft's recommendations and invent custom security baselines with no documentation

D) Disable baseline enforcement entirely because Windows defaults are already considered sufficient

QUESTION 10 · EXAM SCENARIO

Configuration drift has been detected on several production servers: unauthorized software is installed, firewall rules have been modified, and the EDR agent has been disabled. Which solution BEST restores the secure baseline AND prevents recurrence?

A) Ignore the drift as long as the affected services remain running and accessible

B) Reinstall the operating system from scratch on every affected server every week

C) Use configuration management tools such as Ansible or SCCM to continuously detect drift and automatically remediate endpoints to the secure baseline

D) Disable the configuration management system so it does not interrupt production services

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option B — Build a CIS-hardened gold image and deploy it enterprise-wide through System Center Configuration Manager (SCCM)

A gold image is a pre-hardened, pre-configured master template captured once and cloned to every endpoint. Combined with an enterprise deployment tool such as SCCM, Intune, or Ansible, it guarantees that every workstation boots up with the exact same secure baseline (CIS hardening, EDR, patching policies, MFA). Manual approaches (A, D) are inconsistent, slow, error-prone, and unscalable. Letting users choose their own tools (C) destroys any baseline whatsoever.

Question 2: Option B — Use Ansible playbooks that reference the CIS Benchmarks to automate hardening at scale across all servers

Ansible is an agentless, idempotent configuration management tool. Playbooks can encode the CIS Benchmarks once and apply them consistently to all 200 servers, with full audit logs and version control. Manual consulting (A) is expensive, slow, and not repeatable. A wiki with no enforcement (C) guarantees drift. Ad-hoc scripts (D) are not auditable or version-controlled and will reintroduce drift immediately.

Question 3: Option B — Create and link Group Policy Objects (GPOs) in Active Directory to push baseline settings to all domain-joined computers

Group Policy Objects (GPOs) are the native, scalable mechanism in Active Directory for distributing a secure baseline to every domain-joined computer. They are centrally managed, automatically reapplied, and provide reporting through GPResult and event logs. Local Security Policy (A) is per-machine and cannot scale. Asking users to run registry scripts (C) is unreliable and a security risk. Disabling enforcement (D) violates the baseline entirely.

Question 4: Option B — Use Microsoft Intune to push and continuously enforce baseline policies from the cloud on every enrolled device

Microsoft Intune is a cloud-based Mobile Device Management (MDM) and Mobile Application Management (MAM) platform that delivers baseline configuration profiles, compliance rules, and conditional access from the cloud. It works for remote, mobile, and never-VPN devices. Annual visits (A) leave endpoints unprotected for 364 days. GPO/VPN-only (C) fails when devices are offline. A PDF (D) provides zero enforcement.

Question 5: Option B — Use Ansible with idempotent playbooks referencing the CIS-hardened secure baseline, run on a continuous schedule

Ansible playbooks are idempotent—running them repeatedly converges the system to the desired state without side effects. Combined with a scheduled run (or a pull-mode agent), Ansible automatically detects and corrects drift from the CIS-hardened baseline across all 150 servers. Manual SSH (A) does not scale and is reactive. Relying on memory (C) or end users (D) provides no real baseline enforcement.

Question 6: Option C — Use automated compliance-scanning tools that compare the live endpoint state against the gold image baseline

Automated compliance scanners (e.g., Nessus, Microsoft Defender for Endpoint, CIS-CAT, Intune compliance reports) continuously compare running endpoints against the approved gold image or CIS profile and produce auditable reports. Self-reporting (A) and visual inspections (B) do not scale and are unreliable. Skipping verification (D) guarantees that drift goes undetected, defeating the purpose of having a baseline.

Question 7: Option B — Build a secure baseline that bundles mandatory EDR, automatic patching, MFA, and CIS hardening, and deploy it through Intune and SCCM

The root cause was the absence of a consistent secure baseline. The proper remediation is to define one baseline (gold image + automated policies) that mandates EDR, automatic patching, MFA, and CIS hardening, and then deploy it at scale through enterprise management tools (Intune for cloud-managed devices, SCCM for on-prem). Email reminders (A) provide no enforcement. Disabling security (C) and per-department selection (D) re-create the same vulnerabilities that caused the breach.

Question 8: Option A — Implement a CIS-hardened gold image with EDR, MFA, and automated patching, and deploy it via enterprise management tooling such as SCCM or Intune

HIPAA requires safeguards (administrative, physical, and technical) for ePHI. The best technical safeguard is a CIS-hardened gold image that bundles EDR (malware protection), MFA (access control), and automated patching (vulnerability management), deployed through enterprise tooling so every workstation is identical and auditable. Consumer AV (B), BYOD without standards (C), and skipping hardening (D) all violate HIPAA's technical safeguard requirements.

Question 9: Option B — Import the Microsoft Security Baselines as ADMX templates, deploy them through Group Policy, and enforce via SCCM

Microsoft publishes Security Baselines (ADMX/ADML templates, GPO backups, and SCCM configuration items) tuned by Microsoft engineers. Importing these templates into Group Policy and combining them with SCCM gives centralized, automated, and auditable baseline enforcement. Manual copy/paste from screenshots (A) is error-prone and unscalable. Inventing custom baselines (C) loses Microsoft's research. Assuming defaults (D) is unsafe—default Windows settings are permissive by design.

Question 10: Option C — Use configuration management tools such as Ansible or SCCM to continuously detect drift and automatically remediate endpoints to the secure baseline

Drift is exactly what secure baselines and configuration management exist to fight. Ansible (or SCCM Desired Configuration Management) can continuously scan for drift and either alert or automatically re-converge systems to the approved baseline. Ignoring drift (A) leaves the environment unhardened. Weekly reinstalls (B) are destructive and unscalable. Disabling configuration management (D) is the opposite of a baseline and re-creates the original problem.